

ITA1412 -ETHICAL HACKING

Experiment no:7

Experiment Name: Vulnerabilities Analysis Using CGI Scanning With Nikto

Procedure:

Step 1: open a terminal window and type nikto -H and press enter

Step 2: Type nikto -h <website> Tuning x and press enter

Step 3: Nikto starts web server scanning with all tuning options enabled.

Step 4: In the terminal window type “nikto -h <website>-Cgidirs all”and hit enter

Step 5:Nikto will scan the webserver as it looks vulnerable CGI directories. It scans the webserverand list out the directories

Output:

```
kali@kali: ~  
Session Actions Edit View Help  
zsh: corrupt history file /home/kali/.zsh_history  
(kali@kali)~  
$ ping google.com  
PING google.com (142.251.220.110) 56(84) bytes of data.  
64 bytes from hkg07s52-in-f14.1e100.net (142.251.220.110): icmp_seq=1 ttl=64 time=455 ms  
64 bytes from hkg07s52-in-f14.1e100.net (142.251.220.110): icmp_seq=2 ttl=64 time=276 ms  
64 bytes from hkg07s52-in-f14.1e100.net (142.251.220.110): icmp_seq=3 ttl=64 time=45.1 ms  
64 bytes from hkg07s52-in-f14.1e100.net (142.251.220.110): icmp_seq=4 ttl=64 time=209 ms  
64 bytes from hkg07s52-in-f14.1e100.net (142.251.220.110): icmp_seq=5 ttl=64 time=89.0 ms  
^C  
--- google.com ping statistics ---  
5 packets transmitted, 5 received, 0% packet loss, time 4034ms  
rtt min/avg/max/mdev = 45.063/214.602/454.648/145.538 ms  
(kali@kali)~  
$ nikto -Version  
Nikto 2.6.0 (LW 2.5)  
(kali@kali)~  
$ nikto -Help  
  
Options:  
-Add-header      Add HTTP headers (can be used multiple times, one per header pair)  
-ask+           Whether to ask about submitting updates  
                 yes   Ask about each (default)  
                 no   Don't ask, don't send  
                 auto  Don't ask, just send  
-check6         Check if IPv6 is working (connects to ipv6.google.com or value set in nikto.conf)  
-Cgidirs+       Scan these CGI dirs: "none", "all", or values like "/cgi/ /cgi-a/"  
-config+       Use this config file  
-Display+      Turn on/off display outputs:  
                 1     Show redirects  
                 2     Show cookies received  
                 3     Show all 200/OK responses  
                 4     Show URLs which require authentication  
                 D     Debug output  
                 E     Display all HTTP errors  
                 P     Print progress to STDOUT  
                 S     Scrub output of IPs and hostnames  
                 V     Verbose output  
-dbcheck        Check database and other key files for syntax errors  
-evasion+      Encoding technique:  
                 1     Random URI encoding (non-UTF8)  
                 2     Directory self-reference (../)  
                 3     Premature URL ending  
                 4     Prepend long random string  
                 5     Fake parameter  
                 6     TAB as request spacer  
                 7     Change the case of the URL  
                 8     Use Windows directory separator (\)  
                 A     Use a carriage return (0x0d) as a request spacer
```

```
kali@kali: ~  
Session Actions Edit View Help  
ge.html 7 Change the case of the URL  
8 Use Windows directory separator (\)  
A Use a carriage return (0x0d) as a request spacer  
B Use binary value 0x0b as a request spacer  
-followredirects Follow 3xx redirects to new location  
-Format+ Save file (-o) format:  
csv Comma-separated-value  
json JSON Format  
htm HTML Format  
sql Generic SQL (see docs for schema)  
txt Plain text  
xml XML Format  
(if not specified the format will be taken from the file extension passed to -o  
utput)  
-Help This help information  
-host+ Target host/URL  
-id+ Host authentication to use, format is id:pass or id:pass:realm  
-ipv4 IPv4 Only  
-ipv6 IPv6 Only  
-key+ Client certificate key file  
-list-plugins List all available plugins, perform no testing  
-maxtime+ Maximum testing time per host (e.g., 1h, 60m, 3600s)  
-mutate+ Guess additional file names:  
1 Test all files with all root directories  
2 Guess for password file names  
3 Enumerate user names via Apache (/~user type requests)  
4 Enumerate user names via cgiwrap (/cgi-bin/cgiwrap/~user type requests)  
6 Attempt to guess directory names from the supplied dictionary file  
-mutate-options Provide information for mutates  
-nocheck Don't check for updates on startup  
-nocookies Do not use cookies from responses in requests  
-nointeractive Disables interactive features  
-nolookup Disables DNS lookups  
-nossll Disables the use of SSL  
-noslash Strip trailing slash from URL (e.g., '/admin/' to '/admin')  
-no404 Disables nikto attempting to guess a 404 page  
-Option Over-ride an option in nikto.conf, can be issued multiple times  
-output+ Write output to this file ('.' for auto-name)  
-Pause+ Pause between tests (seconds)  
-Platform+ Platform of target (nix, win, all)  
-Plugins+ List of plugins to run (default: ALL)  
-port+ Port to use (default 80)  
-RSAcert+ Client certificate file  
-root+ Prepend root value to all requests, format is /directory  
-Save Save positive responses to this directory ('.' for auto-name)  
-ssl Force ssl mode on port  
-Tuning+ Scan tuning:  
1 Interesting File / Seen in logs  
2 Misconfiguration / Default File  
3 Information Disclosure  
4 Injection (XSS/Script/HTML)
```

```

ge.html
2 Misconfiguration / Default File
3 Information Disclosure
4 Injection (XSS/Script/HTML)
5 Remote File Retrieval - Inside Web Root
6 Denial of Service
7 Remote File Retrieval - Server Wide
8 Command Execution / Remote Shell
9 SQL Injection
0 File Upload
a Authentication Bypass
b Software Identification
c Remote Source Inclusion
d Webservice
e Administrative Console
x Reverse Tuning Options (i.e., include all except specified)

-timeout+ Timeout for requests (default 10 seconds)
-Userdbs Load only user databases, not the standard databases
        all Disable standard dbs and load only user dbs
        tests Disable only db_tests and load udb_tests
-useragent Force User-Agent instead of pulling from database
-url+ Target host/URL (alias of -host)
-useproxy Use the proxy defined in nikto.conf, or argument http://server:port
-Version Print plugin and database versions
-vhost+ Virtual host (for Host header)
-404code Ignore these HTTP codes as negative responses (always). Format is "302,301".
-404string Ignore this string in response body content as negative response (always). Can be a
regular expression.

```

+ requires a value

Want to know more about Kali? Search for it here!



```
(kali@kali)-[~]
```

```
$ nikto -h testphp.vulnweb.com
```

```
- Nikto v2.6.0
```

[Documentation](#)

[Kali Tools](#)

```
+ [FAIL] Unable to connect to testphp.vulnweb.com:80.
```

```
(kali@kali)-[~]
```

```
$ nikto -h https://testphp.vulnweb.com
```

```
- Nikto v2.6.0
```

```
+ [FAIL] Unable to connect to testphp.vulnweb.com:443.
```

```
(kali@kali)-[~]
```

```
$ apache2 -v
```

```
Server version: Apache/2.4.68 (Debian)
```

```
Server built: 2026-06-11T18:22:17
```

```
(kali@kali)-[~]
```

```
$ sudo systemctl start apache2
```

```
[sudo] password for kali:
```

Server built: 2026-06-11T18:22:17

```
(kali@kali)-[~]
$ sudo systemctl start apache2
[sudo] password for kali:
```

```
(kali@kali)-[~]
$ nikto -h http://127.0.0.1
- Nikto v2.6.0
```

```
+ Target IP: 127.0.0.1
+ Target Hostname: 127.0.0.1
+ Target Port: 80
+ Platform: Linux/Unix
+ Start Time: 2026-07-20 01:09:01 (GMT-4)

+ Server: Apache/2.4.68 (Debian)
+ ERROR: Failed to check for updates: 403
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [999984] /: Server may leak inodes via ETags, header found with file /, inode: 29cf, size: 6545fc74d1156, mt
ime: gzip. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/e
n-US/docs/Web/HTTP/CSP
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en
-US/docs/Web/HTTP/Headers/X-Content-Type-Options
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org
/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/
docs/Web/HTTP/Headers/Permissions-Policy
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/doc
s/Web/HTTP/Headers/Referrer-Policy
+ [999990] OPTIONS: Allowed HTTP Methods: GET, POST, OPTIONS, HEAD .
+ [001406] /server-status: The mod_status module reveals Apache information. See: https://httpd.apache.org/doc
s/2.4/mod/mod_status.html

+ [007342] /: X-Frame-Options header is deprecated and was replaced with the Content-Security-Policy HTTP head
er with the frame-ancestors directive. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Header
s/X-Frame-Options
+ [007352] /: The X-Content-Type-Options header is not set. This could allow the user agent to render the cont
ent of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-sca
nner/vulnerabilities/missing-content-type-header/
+ 8083 requests: 16 errors and 10 items reported on the remote host
+ End Time: 2026-07-20 01:15:03 (GMT-4) (362 seconds)
```

+ 1 host(s) tested

```
*****
Portions of the server's headers (Apache/2.4.68) are not in
the Nikto 2.6.0 database or are newer than the known string. Would you like
to submit this information (*no server specific data*) to CIRT.net
```

+ 1 host(s) tested

```
*****
Portions of the server's headers (Apache/2.4.68) are not in
the Nikto 2.6.0 database or are newer than the known string. Would you like
to submit this information (*no server specific data*) to CIRT.net
for a Nikto update (or you may email to sullo@cirt.net) (y/n)? y
```

- Sent updated info to cirt.net -- Thank you!